



UNIVERSITÀ
DEGLI STUDI
DI TRIESTE

SAST & SCA Analysis of Redis and CIE NIS Java SDK using SonarCloud and OWASP Dependency Check

Department of Engineering and Architecture

Trieste, 27 November 2025

THE REPOS

REDIS

- In-memory “database”
- World-class performance, widely used, written in C
- Created by an Italian (Antirez)
- Few dependencies: jemalloc, lua, hiredis, linenoise

CIE NSI SDK

- SDK to check validity of NSI numbers through a shared protocol
- Written in Java
- Only one dependency: BouncyCastle
- Very critical codebase for PA operations

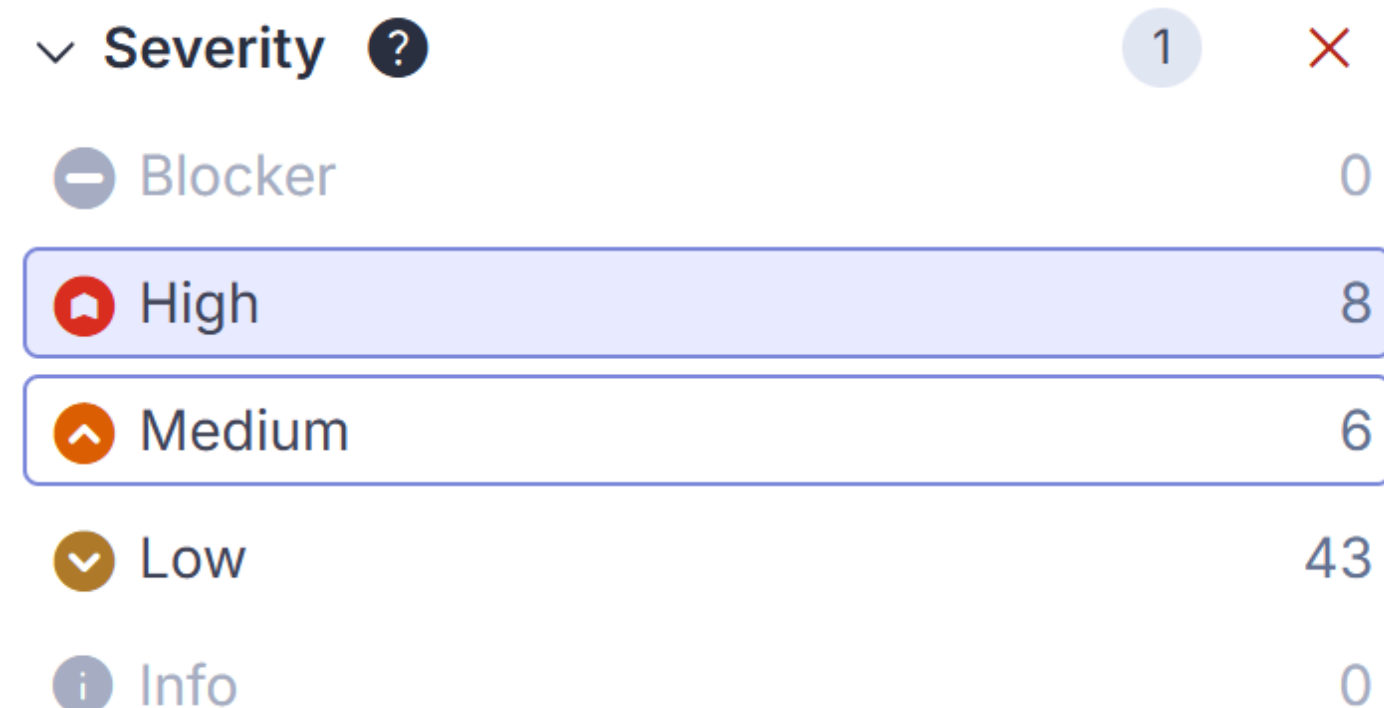
REDIS V6 [2023] (SAST)



- Mostly maintainability issues
- Very few security issues (but very bad)
- Some reliability issues can have dangerous security implications (e.g. buffer overflows)

REDIS V6 [2023] – SAMPLE CVE

- Fixed in Redis v6.2
- Out of bounds write in the hyperloglog.c file
- Not spotted by SonarQube



Completely different LoC,
marked as maintainability issues

CVE-2025-32023 Detail

Description

Redis is an open source, in-memory database that persists on disk. From 2.8 to before 8.0.3, 7.4.5, 7.2.10, and 6.2.19, an authenticated user may use a specially crafted string to trigger a stack/heap out of bounds write on hyperloglog operations, potentially leading to remote code execution. The bug likely affects all Redis versions with hyperloglog operations implemented. This vulnerability is fixed in 8.0.3, 7.4.5, 7.2.10, and 6.2.19. An additional workaround to mitigate the problem without patching the redis-server executable is to prevent users from executing hyperloglog operations. This can be done using ACL to restrict HLL commands.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 7.8 HIGH

Vector:

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H



CNA: GitHub, Inc.

Base Score: 7.0 HIGH

Vector:

CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H

CIE NSI JAVA SDK (SAST)



- Only one security issue (we'll see later)
- A few mild reliability issues
- Some maintainability issues with a very mild rating

CIE NSI JAVA SDK – SECURITY AND RELIABILITY

RELIABILITY EXAMPLE

```
public class Asn1Tag {  
  
    protected byte unusedBits=0;  
    byte[] tag = null;  
    private byte[] data;  
    private List<Asn1Tag> children;  
    private long startPos, endPos, constructed, childSize = 0;  
    private int size;  
    protected static int iterazione;  
  
    protected Asn1Tag(Object[] objects) throws Exception {  
        this.tag = new byte[objects.length];  
        for(int i=0; i<objects.length; i++)  
            this.tag[i] = (Byte)objects[i];  
    }  
  
    protected static long unsignedToBytes32(int x) throws Exception {  
        if(x > 0) return x;  
        long res = (long)(Math.pow(2, 32)) + x;  
        return res;  
    }  
}
```

SECURITY EXAMPLE

```
private void createPublicKey(byte[] modulo, byte[] esponente) throws  
Exception{  
    BigInteger modulus = new BigInteger(AppUtil.bytesToHex(modulo), 16);  
    BigInteger privateExp = new BigInteger(AppUtil.bytesToHex(esponente),  
16);  
  
    RSAPublicKeySpec pubKeySpec = new RSAPublicKeySpec(modulus, privateExp  
);  
  
    cipher = Cipher.getInstance("RSA/ECB/NoPadding");  
    KeyFactory keyFactory = KeyFactory.getInstance("RSA");  
    this.key = (RSAPublicKey) keyFactory.generatePublic(pubKeySpec);  
}
```

REDIS & CIE NSI JAVA SDK (SCA)

- Redis includes its dependencies directly in the repo as source code, thus OWASP doesn't recognize them
- The NSI Java SDK uses a custom script to download dependencies, thus OWAS doesn't find them from the normal repo